Nombre: Cintia Kimberly Altamirano Cundapi
Fecha: 27 de Octubre de 2026

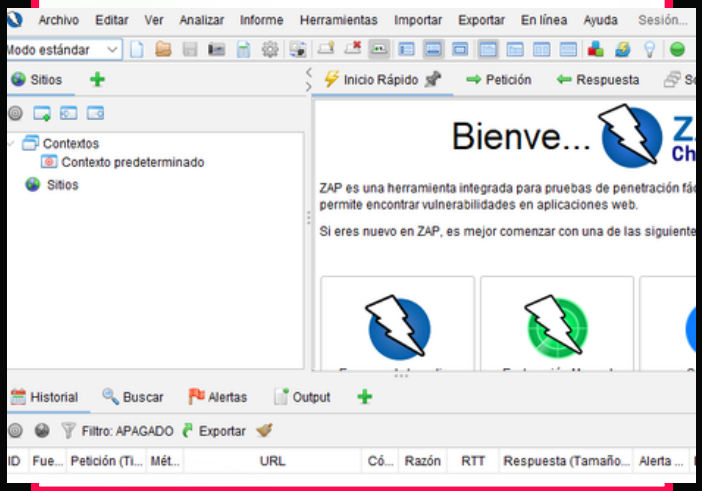
HACKER WOMEN COUNCIL — ETHICAL HACKING

Actividad 04. Primera evaluación de seguridad web

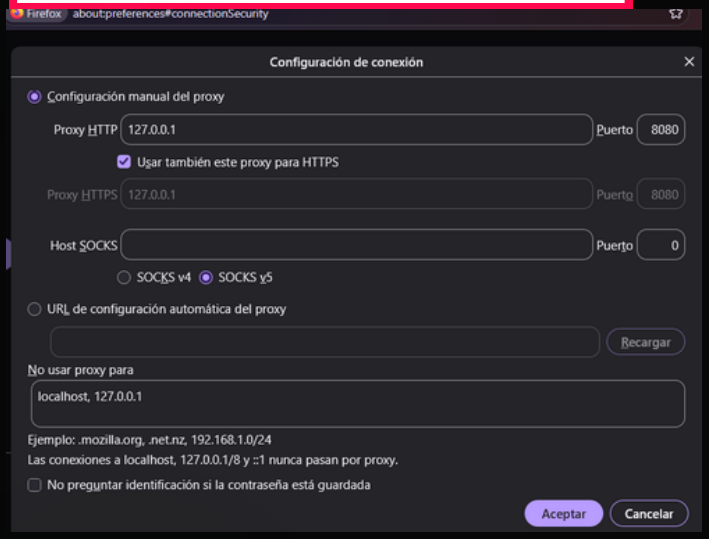
Documentar la evaluación de seguridad web a partir de la página de ginand juice

1 PREPARACIÓN DEL ENTORNO

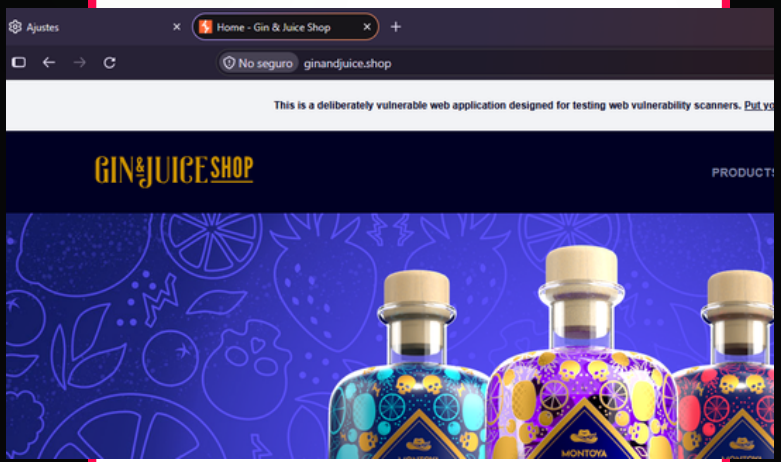
1.1 Zap abierto



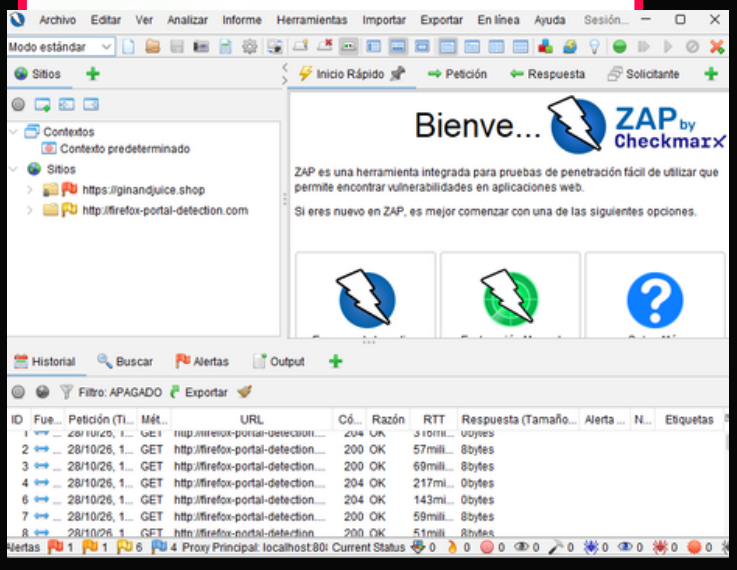
1.2 Navegador configurado



1.3 Acceso a



1.4 Verificación de que el tráfico aparece en ZAP



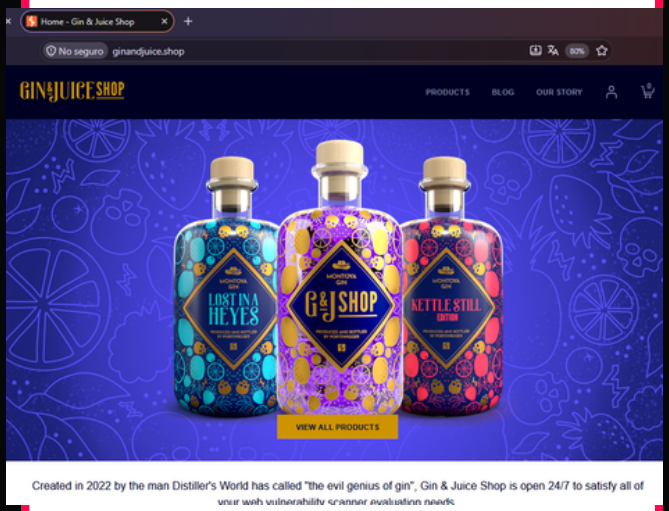
Nombre: Cintia Kimberly Altamirano Cundapi
Fecha: 27 de Octubre de 2026

HACKER WOMEN COUNCIL — ETHICAL HACKING

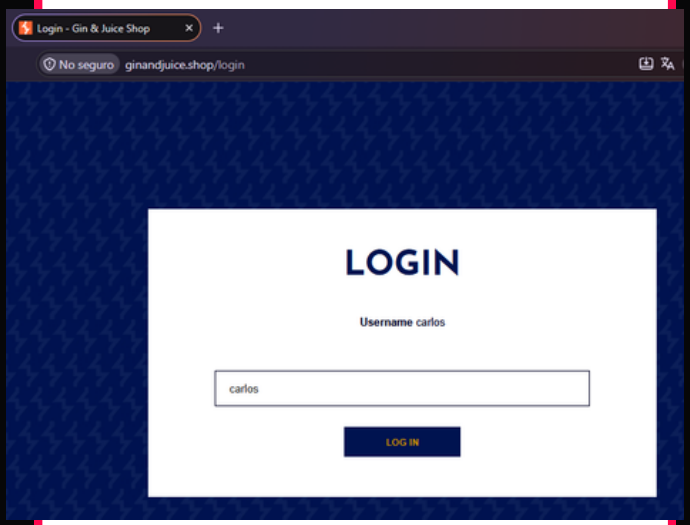
2 EXPLORA LA APLICACIÓN

2.1 Navegación en el sitio

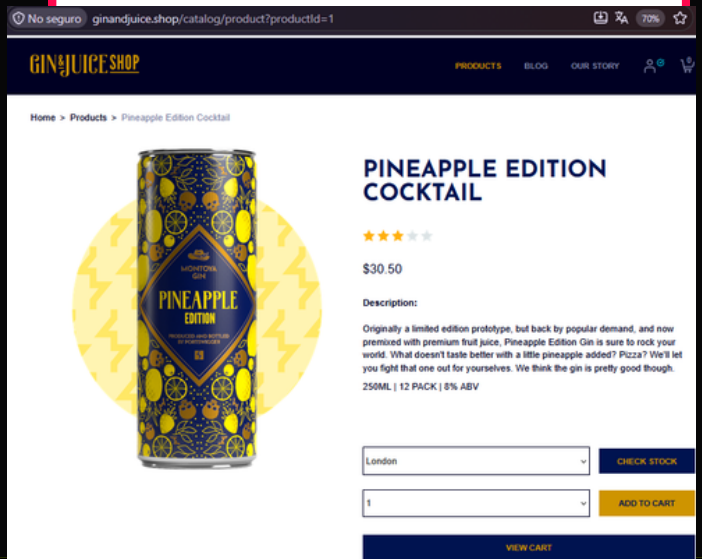
Home - Página de inicio



Login - Inicio de sesión

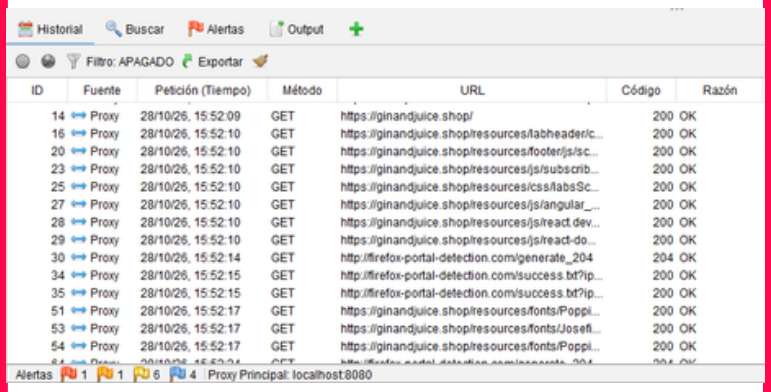


Detalles de producto

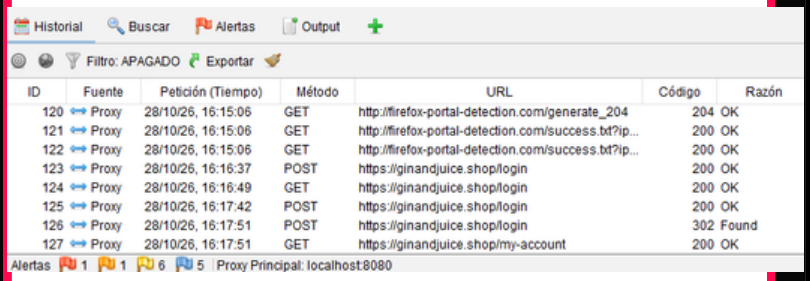


2.2 Tráfico HTTP en ZAP

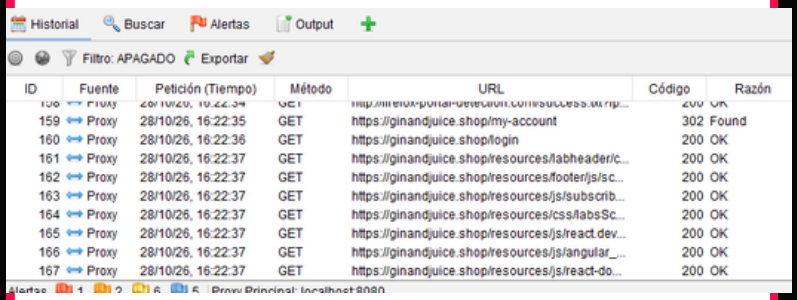
Home - Página de inicio



Login - Inicio de sesión



Detalles de producto



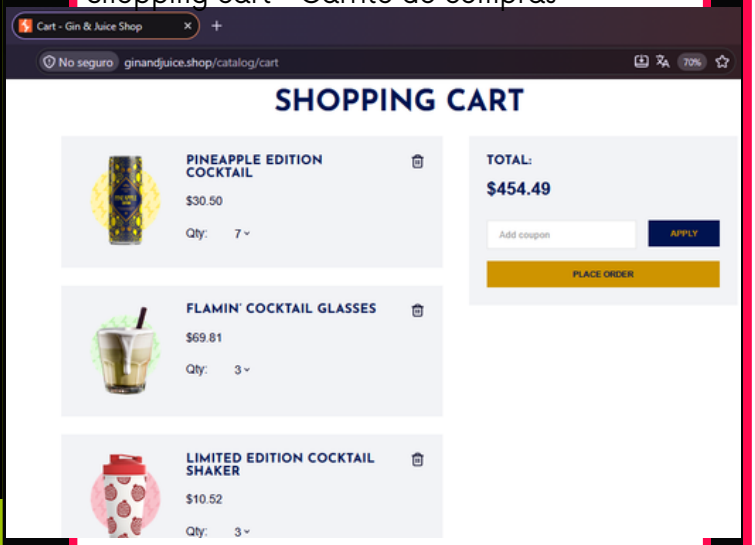
Nombre: Cintia Kimberly Altamirano Cundapi
Fecha: 27 de Octubre de 2026

HACKER WOMEN COUNCIL — ETHICAL HACKING

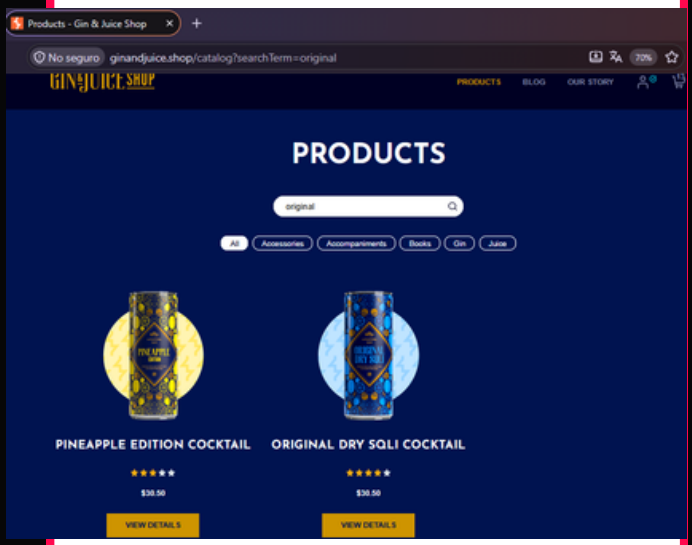
2 EXPLORA LA APLICACIÓN

2.1 Navegación en el sitio

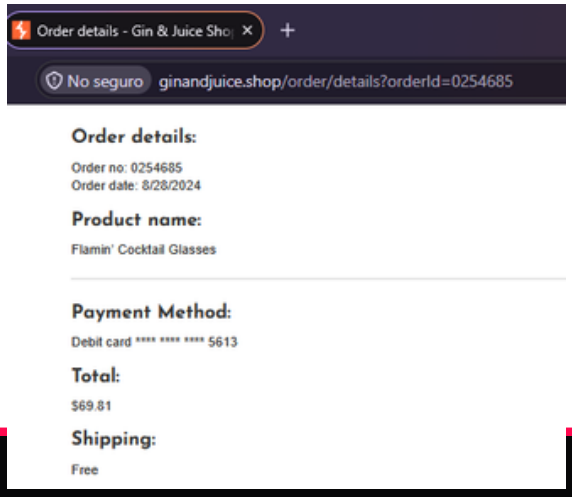
Shopping cart - Carrito de compras



Búsqueda de productos - Search

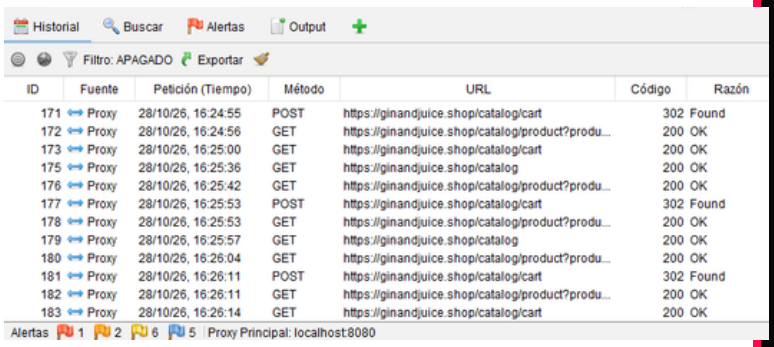


Order details - Detalles de orden

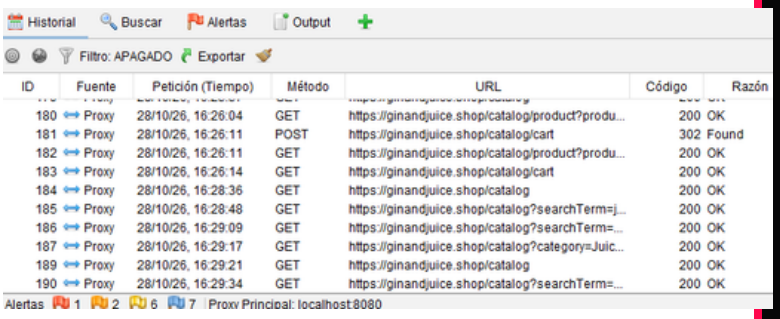


2.2 Tráfico HTTP en ZAP

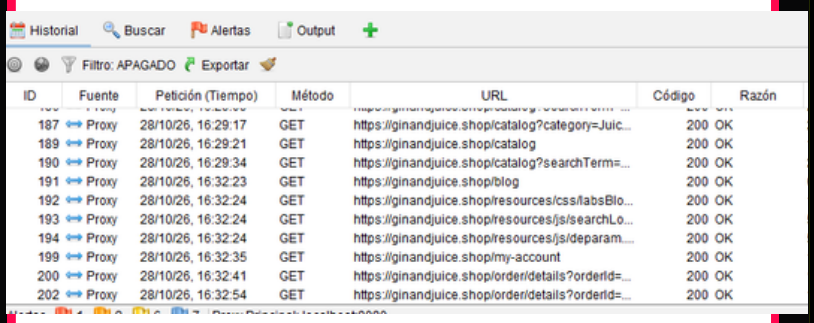
Shopping cart - Carrito de compras



Búsqueda de productos - Search



Order details - Detalles de orden



Nombre: Cintia Kimberly Altamirano Cundapi
Fecha: 27 de Octubre de 2026

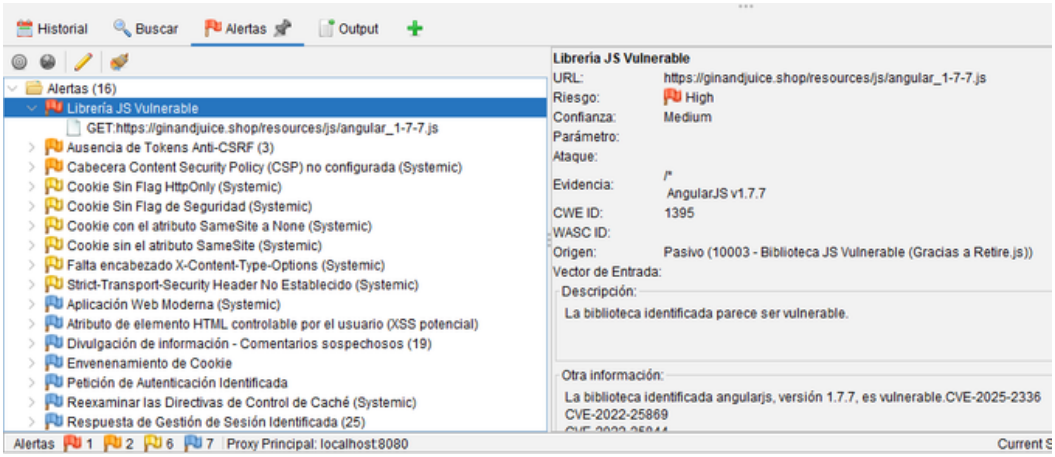
HACKER WOMEN COUNCIL — ETHICAL HACKING

3 **ANALIZA LAS ALERTAS**

Documenta 3 alertas de diferentes tipos

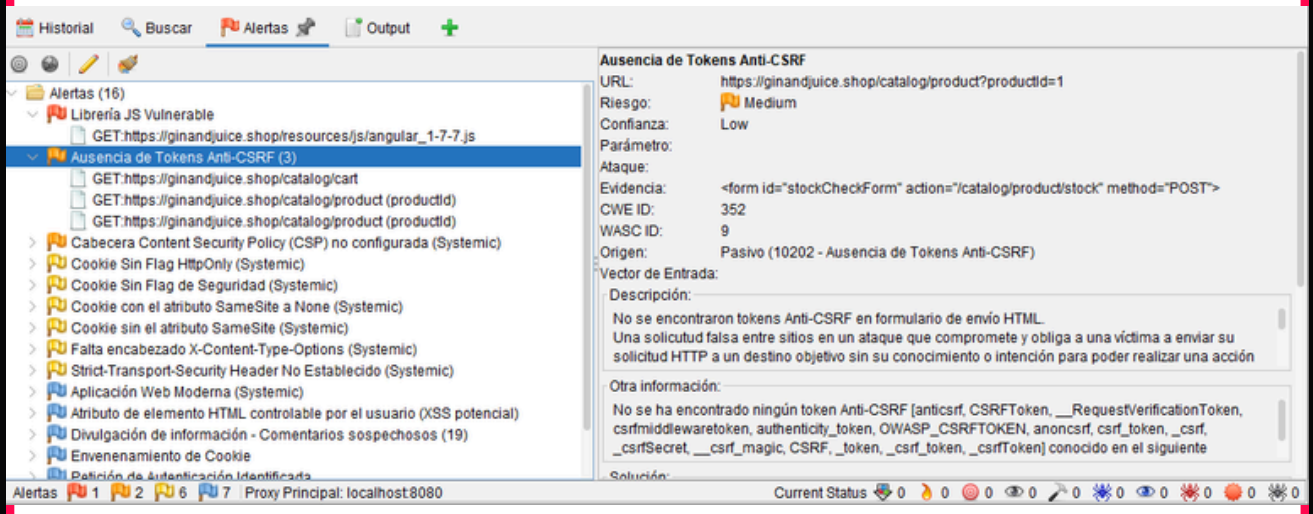
1. LIBRERIA JS VULNERABLE

- Nivel: Riesgo Alto



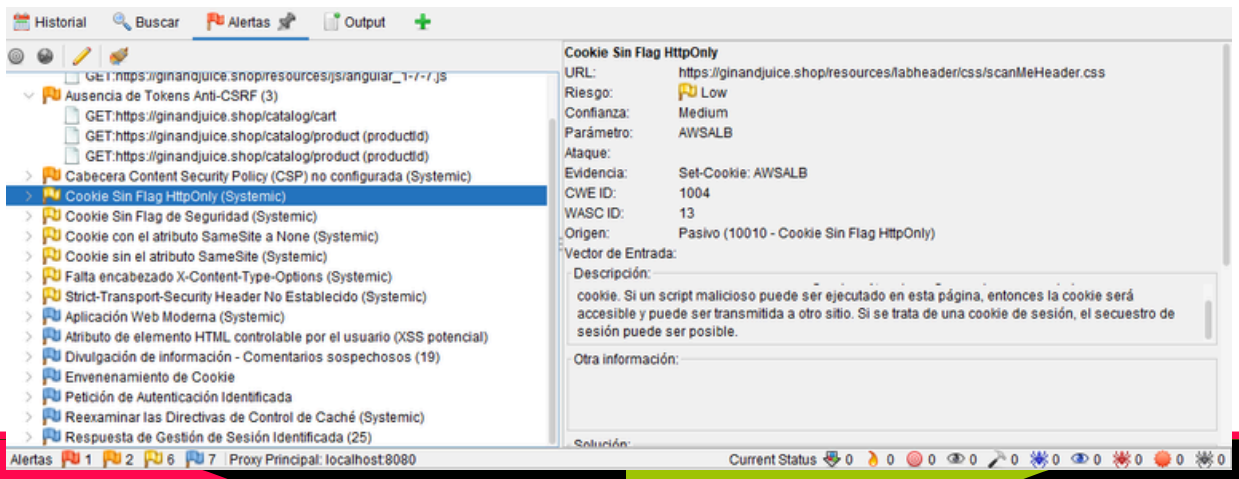
2. AUSENCIA DE TOKENS ANTI-CSRF

- Nivel: Riesgo Medio



3. COOKIE SIN FLAG HTTPONLY

- Nivel: Riesgo Bajo



Nombre: Cintia Kimberly Altamirano Cundapi
Fecha: 27 de Octubre de 2026

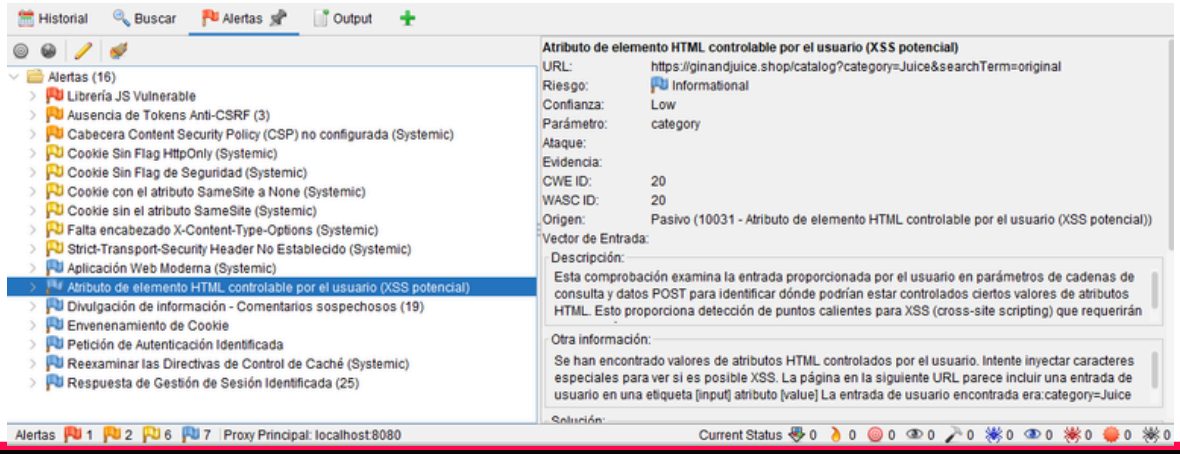
HACKER WOMEN COUNCIL — ETHICAL HACKING

3 ANALIZA LAS ALERTAS

Documenta 3 alertas de diferentes tipos

EXTRA. ATRIBUTO DE ELEMENTO HTML CONTROLADO POR EL USUARIO (XSS POTENCIAL)

- Nivel: Informativa



4 DOCUMENTA UN HALLAZGO PRINCIPAL

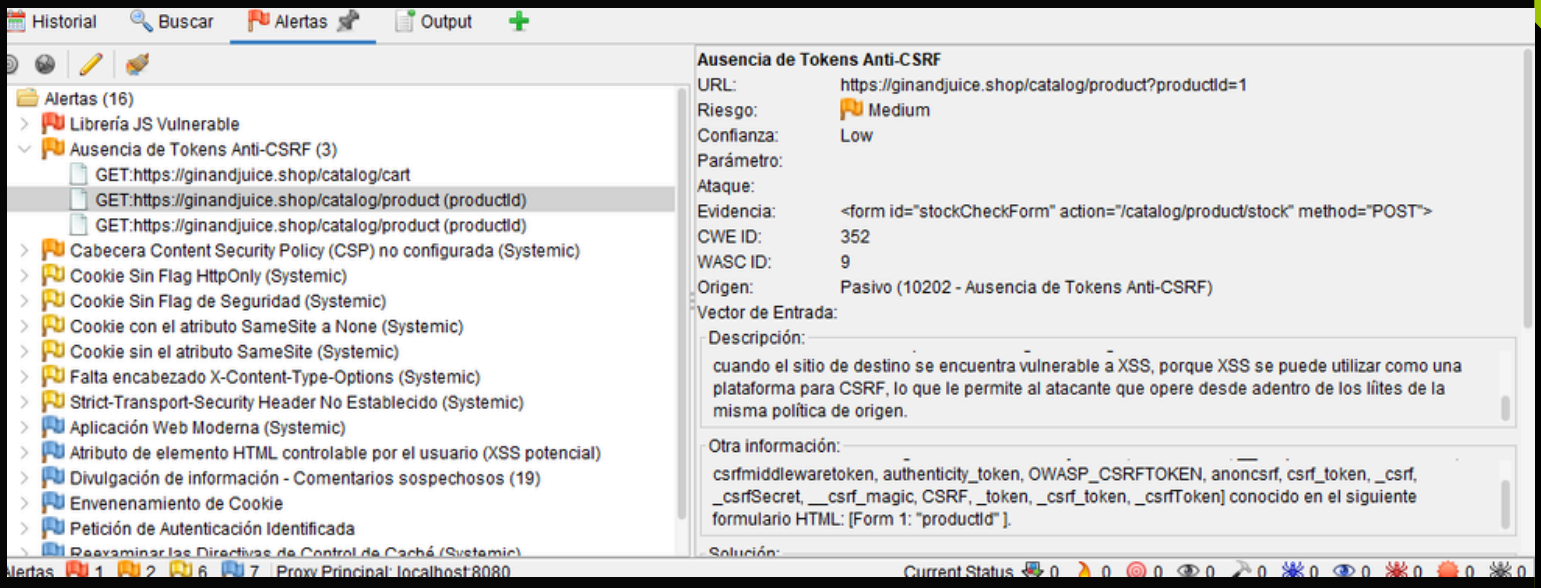
01	Nombre de la alerta	Ausencia de tokens Anti-CSRF
02	Nivel de riesgo	Medio (Medium)
03	URL o Componente	1. GET:https://ginandjuice.shop/catalog/cart 2. GET:https://ginandjuice.shop/catalog/product (productId) Componente analizado: Formulario HTML identificado por ZAP en la ruta de consulta de un producto.
04	Parámetro afectado	ZAP no menciona un parámetro afectado.
05	Evidencia	<form action=/catalog/cart method=POST style="display: inline">
06	Descripción técnica	No se encontraron tokens Anti-CSRF en formulario de envío HTML. Una solicutud falsa entre sitios en un ataque que compromete y obliga a una víctima a enviar su solicitud HTTP a un destino objetivo sin su conocimiento o intención para poder realizar una acción como víctima. La causa oculta es la funcionalidad de la aplicación utilizando acciones de URL/formulario que pueden ser adivinados de forma repetible. La naturaleza del ataque es que CSRG explota la confianza que un sitio web proporciona a un usuario. Por el contrario, las cadenas de comandos de los sitios cruzados (XSS) explotan la confianza que un usuario proporciona en un sitio web. Al igual que XSS, los ataques CSRG no son de forma necesaria de sitios cruzados, pero hay la posibilidad de que si pueden serlo. La falsificación de las solicitudes ente los sitios también se conoce como CSRF, XSRG, ataques con un solo clic, montaje de sesión, diputado confundido y navegación en alta mar. Los ataques de CSRG son muy efectivos en varias situaciones, que incluyen: *La victima tiene una sesión activa en el sitio de destino. *La víctima se autoriza por medio de la autenticación HTTP en el sitio de destino. *La víctima se encuentra en la misma red local que el sitio de destino. CSRF se ha utilizado especialmente para poder realizar una acción contra un sitio objetivo utilizando los privilegios de la víctima, pero se han revelado técnicas recientes para difundir información al obtener el acceso a la respuesta. El riesgo de divulgación de información aumenta de forma drástica cuando el sitio de destino se encuentra vulnerable a XSS, porque XSS se puede utilizar como una plataforma para CSRF, lo que le permite al atacante que opere desde adentro de los liites de la misma política de origen.

Nombre: Cintia Kimberly Altamirano Cundapi
Fecha: 27 de Octubre de 2026

HACKER WOMEN COUNCIL — ETHICAL HACKING

4 DOCUMENTA UN HALLAZGO PRINCIPAL (CONTINUACIÓN)

07	Impacto potencial	Si la solicitud solamente muestra los detalles de un producto y no modifica el estado de la aplicación, el riesgo de CSRF asociado a esa operación podría ser limitado. Sin embargo, si existieran operaciones sensibles sin protección adecuada, un atacante podría intentar inducir a un usuario autenticado a enviar solicitudes no deseadas utilizando su sesión activa. En el contexto de una tienda en línea como Gin and Juice Shop, el impacto dependería de las funcionalidades realmente afectadas. Por ejemplo, si existieran operaciones vulnerables relacionadas con la modificación de datos de una cuenta o de un pedido, podrían producirse cambios no autorizados. No obstante, la alerta analizada no demuestra que esas operaciones existan ni que sean vulnerables. Por lo tanto, el principal riesgo identificado es la necesidad de verificar que las solicitudes que modifican información estén protegidas adecuadamente contra ataques CSRF.
08	Recomendación	Se recomienda al equipo responsable de Gin and Juice Shop revisar los mecanismos de protección contra CSRF y verificar si el formulario identificado necesita controles adicionales. Las principales medidas recomendadas son: 1. Utilizar mecanismos de protección confiables: emplear un framework o una biblioteca de seguridad que facilite la prevención de ataques CSRF y configurar correctamente sus mecanismos de protección. 2. Implementar tokens Anti-CSRF: generar tokens únicos, impredecibles y asociados a las solicitudes que requieren protección. El servidor debe validar estos tokens antes de aceptar una operación sensible. 3. Prevenir vulnerabilidades XSS: corregir las posibles vulnerabilidades de Cross-Site Scripting, ya que un atacante que consiga ejecutar código malicioso en el contexto de la aplicación podría evadir algunas defensas contra CSRF. 4. Proteger las operaciones sensibles: identificar las acciones que puedan modificar información y, cuando corresponda, solicitar una confirmación adicional antes de ejecutarlas. 5. Evitar cambios de estado mediante GET: utilizar métodos HTTP adecuados, como POST, para las operaciones que modifican información, y no permitir que una simple solicitud GET ejecute cambios en el estado de la aplicación. 6. Validar el origen de las solicitudes: utilizar comprobaciones apropiadas de los encabezados Origin y Referer como medidas complementarias, considerando que el encabezado Referer puede estar ausente por motivos de privacidad. 7. Revisar la gestión de sesiones: utilizar mecanismos seguros de administración de sesiones y comprobar que las solicitudes que modifican información estén correctamente protegidas. Una consideración para el hallazgo es: como la alerta se detectó en la URL https://ginandjuice.shop/catalog/product?productId=1, primero debe verificarse si el formulario realiza únicamente una consulta del catálogo o si permite ejecutar una operación que modifica información. Si solo consulta un producto, la ausencia de un token no confirma por sí sola una vulnerabilidad CSRF ni implica que todas estas medidas sean necesarias para esa solicitud concreta.



HACKER WOMEN COUNCIL — ETHICAL HACKING

5

CONCLUSIONES

Documenta 3 elementos

¿QUÉ APRENDÍ?

Aprendí a utilizar ZAP para analizar una aplicación web e identificar posibles vulnerabilidades y configuraciones de seguridad deficientes. Durante la práctica revisé el tráfico y las alertas generadas por la herramienta, sus niveles de riesgo, las URL afectadas y las recomendaciones para reducir los riesgos detectados.

- Entre los hallazgos que identifiqué con ZAP se encuentran una biblioteca JavaScript vulnerable, la ausencia de tokens Anti-CSRF en un formulario y la falta de configuración de la cabecera Content-Security-Policy (CSP).

¿QUÉ FUE LO MÁS RETADOR?

Una de mis principales dificultades fue configurar el navegador para que su tráfico pasara por ZAP y reconocer dónde consultar las solicitudes, respuestas y alertas generadas durante la navegación. También fue necesario interpretar los resultados técnicos y distinguir entre los riesgos potenciales y aquellos cuyo impacto depende del funcionamiento de la aplicación.

- Para resolverlo, configuré el proxy del navegador, recorrí el sitio de prueba, revisé las alertas y consulté sus descripciones, evidencias y recomendaciones o soluciones. Esto me permitió seleccionar hallazgos relevantes y comprender mejor qué información debía documentarse en el reporte.

¿QUÉ REVISARIA A CONTINUACIÓN?

En una evaluación posterior revisaría con mayor detalle los componentes vulnerables y comprobaría si la versión identificada de la biblioteca JavaScript presenta riesgos aplicables al sitio. También verificaría si el formulario señalado necesita protección contra CSRF según las operaciones que permite realizar y comprobaría la configuración de las cabeceras de seguridad. Finalmente, realizaría pruebas adicionales de forma controlada para validar los hallazgos, revisar las posibles consecuencias y determinar qué medidas correctivas corresponden.

Risk Level	Name	URL	Parameter	Evidence
Alto	Librería JS Vulnerable	https://ginandjuice.shop/resources/js/angular_1-7-7.js		/* AngularJS v1.7.7
Medio	Ausencia de Tokens Anti-CSRF	https://ginandjuice.shop/catalog/product?productId=1		<form id="stockCheckForm" action="/catalog/product/stock" method="POST">
Bajo	Cookie Sin Flag HttpOnly	https://ginandjuice.shop/resources/labheader/css/scanMeHeader.css	AWSALB	Set-Cookie: AWSALB

Nombre: Cintia Kimberly Altamirano Cundapi
Fecha: 27 de Octubre de 2026